

VST-Sentry

A desktop security scanner for Windows VST / DLL plugin files. VST-Sentry performs static analysis on Portable Executable (PE) files to detect indicators of malicious intent — DLL hijacking payloads, trojanised installers, crypto-miners, and packed/encrypted binaries — before they reach your DAW.

What's New in v2.5

v2.5.0 — Drag-and-Drop Folder Support

- **Folder Drop** — Drop an entire VstPlugins directory (or any folder) onto the drop zone and VST-Sentry recursively discovers every .dll, .vst3, and .vst file inside, then queues them all as a batch scan
- **Mixed Drop** — Freely mix individual files and folders in a single drop; folders are expanded, files are validated, and duplicates are removed automatically
- **Shared Discovery** — Both drop-zone and File > Scan Folder now use the same `_collect_plugins_from_dir` helper for consistent recursive scanning
- **Updated Drop Zone** — Label now reads "Drop files or folders here" with a note about recursive scanning

v2.4.0 — Multi-Drop, PDF Export & Update Check

- **Multi-File Drag-and-Drop** — Drop multiple DLL/VST files at once and they are automatically queued as a batch scan with a summary at the end
- **PDF Report Export** — Export analysis reports as PDF files (Ctrl+E > Save as .pdf) using a zero-dependency PDF generator — no external libraries needed
- **Auto-Update Check** — Help > Check for Updates queries GitHub releases in the background and prompts you if a newer version is available
- **Rich History Tooltips** — History card tooltips now show file size, SHA-256 prefix, VT detection ratio, scan duration, and full path
- **Scan Progress Percentage** — The elapsed-time display now includes a step percentage (e.g., "3.2s · 50%") so you can see exactly where the pipeline is

v2.3.0 — Statistics & Shortcuts

- **Statistics Footer** — Persistent footer bar showing lifetime scan counts by verdict (Safe/Suspicious/High Risk) with a version tag
- **Keyboard Shortcut Cheat Sheet** — Press F1 or Help > Keyboard Shortcuts to see a styled overlay with all shortcuts and key badges

- **Session Scan Counter** — Internal counter tracking scans per session, updates the stats footer after each analysis

v2.2.0 — Interaction & Comparison

- **Copy SHA-256 to Clipboard** — One-click button copies the file hash to your clipboard with a green "Copied!" flash confirmation
- **Compare Scans** — View > Compare Scans opens a dialog to select two history entries and renders a side-by-side diff table in the log, highlighting differences
- **Enhanced Drag Feedback** — Drop zone changes icon (↴ → ⬇), label ("Release to scan"), and border colour when dragging a file over it
- **Notification Sound** — System bell on scan completion (configurable via `ENABLE_SOUND` constant)
- **Log Severity Icons** — Timestamped log lines now display ✓/△/✖ Unicode icons for success/warning/error messages
- **Scan Duration Tracking** — Elapsed time recorded in each history entry (`elapsed_seconds` field)
- **New Palette Colours** — `drop_active` for drag-over border, `clipboard` for copy confirmation flash

v2.1.0 — Visual Polish & Export

- **Summary Dashboard Cards** — Five at-a-glance metric cards (Verdict, Risk Score, Flagged APIs, VirusTotal, Entropy) appear after each scan with colour-coded values
- **HTML Report Export** — Export analysis reports as styled dark-theme HTML files with summary cards, full report text, and metadata
- **Quarantine Folder** — Option to move suspicious/high-risk files to a timestamped quarantine directory instead of leaving them in place
- **Button Hover Effects** — Subtle background transitions on interactive buttons for better visual feedback
- **Window Title Updates** — Title bar reflects the currently analysed file name during and after scanning

v2.0.0 — UX Overhaul

- **Menu Bar** — Standard File/Edit/View/Help menus with full keyboard shortcut support
- **Keyboard Shortcuts** — Ctrl+O (open), Ctrl+E (export), Ctrl+F (find), Ctrl+L (clear), Ctrl+H (history), F5 (re-scan)
- **Tooltips** — Hover help on all buttons and interactive elements
- **Right-Click Context Menu** — Copy, Select All, Find, and Clear on the analysis log
- **Search in Log** — Ctrl+F opens a find bar with match highlighting, next/prev navigation

- **Scan History Panel** — Persistent sidebar (JSON-backed) showing all past scans with verdict, score, and date; click any entry to re-scan
- **Batch Folder Scan** — Scan all DLL/VST/VST3 files in a directory at once with a summary report
- **Recent Files** — File > Recent Files menu tracking the last 10 scanned files
- **Re-scan Button** — One-click re-analysis of the last file (also F5)
- **Progress Bar** — Animated sliding progress indicator during analysis
- **Elapsed Timer** — Real-time elapsed time display during scans
- **Pulsing Status Dot** — Animated glow ring on the status indicator during analysis
- **Auto-Detect Plugin Paths** — Settings dialog can discover common VST folder paths for Windows, macOS, and Linux
- **First-Run Welcome** — Friendly onboarding dialog on first launch explaining features

Features

- **103 Red-Flag API Detection** — Cross-references the Import Address Table against a curated database of dangerous Windows APIs (process injection, keylogging, networking, privilege escalation, registry manipulation) with weighted severity scoring.
- **Shannon Entropy Analysis** — Per-section and whole-file entropy calculation to flag packed, compressed, or encrypted DLL sections (UPX, ASPack, Themida, VMProtect, etc.).
- **Digital Signature Verification** — Checks Authenticode signatures and flags unsigned binaries carrying suspicious API imports.
- **VirusTotal Integration** — Optional hash-based lookup against 70+ antivirus engines via the VT API v3, with automatic sandbox behaviour retrieval for high-risk verdicts.
- **MITRE ATT&CK Mapping** — Maps sandbox-observed DNS lookups, dropped files, and process commands to ATT&CK technique IDs using a 90+ technique knowledge base.
- **DAW-Themed GUI** — Dark-themed Tkinter interface with drag-and-drop support, real-time analysis log, green/yellow/red status indicator, and auto-install for safe plugins.

Scoring Model

Severity	Points	Examples
CRITICAL	10	CreateRemoteThread, VirtualAllocEx, URLDownloadToFileA
PACKING	6–8	Section entropy >= 7.0, RWX permissions, known packer names
HIGH	7	RegSetValueExA, OpenSCManagerA, AdjustTokenPrivileges
MEDIUM	4	IsDebuggerPresent, GetTickCount, NtQuerySystemInformation
LOW	2	WriteFile, CopyFileA, MoveFileExW

Verdict thresholds: Safe (0–4 pts) · Suspicious (5–19 pts) · High Risk (20+ pts)

VirusTotal adjustments: Clean = -2 pts · Low (1–4 detections) = +10 pts · Medium (5–14) = +20 pts · High (15+) = +30 pts

Project Structure

```
vst-sentry/
├── analyzer.py           # Static analysis engine (1,700 lines)
├── virustotal.py         # VT API v3 client + MITRE KB (715 lines)
├── vst_sentry_gui.py     # Tkinter desktop GUI v2.5 (3,570 lines)
├── test_analyzer.py      # 38 tests – analyzer unit tests
├── test_virustotal.py    # 101 tests – VT client + MITRE tests
├── test_gui.py           # 109 tests + subtests – GUI integration
├── requirements.txt      # Python dependencies
├── scan_history.json     # Auto-generated scan history (JSON)
├── vst_sentry.ini        # Auto-generated user config (INI)
├── VST_Security_Threat_Report.md # Background threat intelligence
└── README.md            # This file
```

Total: ~10,800 lines of Python · 253 tests (206 subtests)

Installation

```
# Clone or download the project
cd vst-sentry

# Create a virtual environment (recommended)
python -m venv .venv
source .venv/bin/activate      # Linux / macOS
.venv\Scripts\activate        # Windows

# Install dependencies
pip install -r requirements.txt
```

Optional: Drag-and-Drop Support

For native OS drag-and-drop on the file drop zone, install `tkinterdnd2`:

```
pip install tkinterdnd2
```

The GUI falls back to a click-to-browse file dialog if this package is not installed.

Usage

Launch the GUI

```
python vst_sentry_gui.py
```

1. **Configure** — Click the gear icon (or File > Settings) to set your DAW plugin folder and (optionally) a VirusTotal API key. Use "Auto-Detect" to find common plugin directories on your system.
2. **Drop or browse** — Drag one or more .dll / .vst3 files onto the drop zone, click to browse, or use Ctrl+O. Multiple dropped files are queued as a batch scan.
3. **Review** — Watch the analysis log for real-time results. Use Ctrl+F to search the log. The status indicator turns green (Safe), yellow (Suspicious), or red (High Risk).
4. **Auto-install** — Safe files are automatically copied to your configured plugin folder.
5. **Batch scan** — Use File > Scan Folder to scan an entire directory of plugins at once.
6. **History** — Toggle the scan history panel (Ctrl+H) to review and re-scan previous files. Hover cards for file details.
7. **Export** — Ctrl+E to save the report as TXT, HTML, PDF, or JSON.
8. **Updates** — Help > Check for Updates to see if a newer version is available.

Keyboard Shortcuts

Shortcut	Action
Ctrl+O	Open file for analysis
Ctrl+E	Export report (TXT/HTML/PDF/JSON)
Ctrl+F	Find in analysis log
Ctrl+L	Clear the analysis log
Ctrl+H	Toggle scan history panel
F5	Re-scan last analysed file
F1	Keyboard shortcut cheat sheet
Escape	Close search bar / dialog

Command-Line / Scripting

```
from analyzer import analyze_file, generate_report

result = analyze_file(r"C:\path\to\plugin.dll", vt_api_key="YOUR_KEY")

print(result["verdict"])      # "Safe", "Suspicious", or "High Risk"
print(result["score"])       # Numeric risk score
print(generate_report(result)) # Full text report
```

VirusTotal API Key

A free-tier key supports 4 requests/minute and 500 requests/day. The scanner works fully offline without a key — the VT lookup is an additive signal, not a gate.

Running Tests

```
pip install pytest

# Run the full suite
python -m pytest test_analyzer.py test_virustotal.py test_gui.py -v

# Run a specific test class
python -m pytest test_gui.py::TestScanHistory -v
```

Expected output: 253 passed, 206 subtests passed.

Architecture

analyzer.py

The static analysis engine. Parses PE files with `pefile`, extracts the Import Address Table, and scores each imported function against the 103-entry Red Flag API database. Also performs Shannon entropy analysis on every PE section, checks for known packer section names (UPX, ASPack, etc.), and verifies Authenticode signatures. Produces a structured `AnalysisResult` dict and a human-readable text report.

virustotal.py

Isolated VirusTotal API v3 client. Handles hash lookups (`/files/{sha256}`), sandbox behaviour retrieval (`/behaviour_summary`), and MITRE ATT&CK technique enrichment from a local 90+ technique knowledge base. Designed to fail gracefully — network errors, rate limits, and missing API keys never block the local analysis pipeline.

vst_sentry_gui.py

Tkinter GUI v2.5 with a DAW-inspired dark theme. Features include a menu bar with keyboard shortcuts, drag-and-drop file and folder loading (single files, multiple files, or entire directories) with recursive plugin discovery and enhanced visual feedback, threaded analysis with animated progress bar, elapsed timer with step percentage, search-in-log with match highlighting, persistent scan history sidebar with rich file-info tooltips, batch folder scanning, recent files tracking, auto-detect plugin folder paths, right-click context menus, tooltips, first-run welcome dialog, summary dashboard cards, export to TXT/HTML/PDF/JSON, quarantine folder for flagged files, button hover effects, copy SHA-256 to clipboard, scan comparison view, notification sound, severity icons in log lines, scan duration tracking, statistics footer, keyboard shortcut cheat sheet, and auto-update check. Runs analysis in a background thread to keep the UI responsive.

License

MIT